Client Authentication

From PostgreSQL wiki

Languages: **English** • Español • 日本語

Who is allowed to connect to the database is controlled by a file in the root of your database directory named. pg_hba.conf (http://www.postgresql.org/docs/current/static/auth-pg-hba-conf.html) . A default file is created when you run initdb to create a database cluster.

What permissions exist by default depends on how initdb was called. By default, new clusters are created with the 'trust' scheme, where any local user is allowed to connect to the database. However, some PostgreSQL packagers may change this. For example, if you use the RedHat 'service initdb' to create your cluster, it calls initdb like this:

```
initdb --pgdata='$PGDATA' --auth='ident sameuser'
```

Which uses the not particularly popular ident scheme to figure out if a user is allowed to connect, much frustrating those who aren't aware of this.

A typical recommended setup for network access to the database takes the local LAN address and only allows clients who authenticate using a secure MD5 password. The entry in pg_hba.conf will look like this:

```
# TYPE  DATABASE    USER        CIDR-ADDRESS          METHOD
host    all         all         192.168.1.0/24        md5
```

This only allows clients with IP addresses from 192.168.1.0-192.168.1.255 to connect, and only then if they provide the correct password for the user. Note that network access like this is only allowed at all if the postgresql.conf setting for listen_addresses (http://www.postgresql.org/docs/current/static/runtime-config-connection.html) allows it.

Database user's passwords are set when you create the user with CREATE ROLE (http://www.postgresql.org/docs/current/static/sql-createrole.html) and can be modified with ALTER ROLE (http://www.postgresql.org/docs/current/static/sql-alterrole.html) . createuser (http://www.postgresql.org/docs/current/interactive/app-createuser.html) can be a useful wrapper script to help with that.

There is a bit of a catch here: since creating a new role requires connecting to the database with a superuser role, how do you get started here? One common approach is to start with a pg_hba.conf that trusts just users connecting on the server itself:

```
# "local" is for Unix domain socket connections only
local   all         all                               trust
# IPv4 local connections:
host    all         all         127.0.0.1/32          trust
```

If the database is configured like this, anyone logged onto the system can now connect to your server at will, so you don't want to keep this configuration for long. What you can now do is use ALTER ROLE (http://www.postgresql.org/docs/current/static/sql-alterrole.html) to assign a strong password to the postgres superuser. Once that's done, you can shutdown the server, change all the "trust" settings to "md5", add your whole network block to pg_hba.conf, and set listen_addresses. When you start it back up again, you'll have one superuser account you know the password to, which you can then use to create all the regular accounts for your users.

LDAP authentication

To pull off ldap authentication, you need to replace 'md5' with

```
:ldap "ldap://server/dc=domain,dc=local;DOMAIN\"
```

Where server and domain are both pretty self explanatory. This is all one user reporting on this feature had to do to accomplish ldap authentication. They use this method for all network addresses in the 192.168.x.x range, and md5 for localhost, so that it can use a username that doesn't exist in ldap for backups. This way only the server itself can initiate backups on the superuser account.

Related articles

- PostgreSQL and pam_ldap (http://itc.musc.edu/wiki/PostgreSQL) by Adrian Nida
- NSS Authentication with libnss_pgsql (http://blue-labs.org/software/pg_nss/index.php) by David Ford
- Authenticating PostgreSQL Clients (http://www.securitypronews.com/2002/0521.html) by SecurityProNews (2002-05-21)
- LDAP Authentication against AD by Joey Wang (2007-04-13)

Retrieved from "https://wiki.postgresql.org/index.php?title=Client_Authentication&oldid=8909"
Categories: FAQ | Administration

- This page was last modified on 26 November 2009, at 04:51.